LAYER8

CLIENTE

Cliente

DOCUMENTO

Relatório Executivo de Segurança

DATA

Fevereiro 2026

CONFIDENCIAL

Sumário Executivo

A **LAYER8** conduziu uma auditoria de segurança abrangente à infraestrutura interna da **Cliente** entre 15 e 19 de Dezembro de 2025. Esta avaliação teve como objetivo identificar vulnerabilidades de segurança, avaliar a postura de segurança da organização e fornecer recomendações estratégicas para mitigar os riscos identificados.

A auditoria revelou **20 vulnerabilidades** distribuídas por diferentes categorias de segurança, incluindo Active Directory, aplicações web, infraestrutura de rede e controlos de acesso. Destas, **4 são de severidade alta**, representando riscos significativos que podem comprometer a confidencialidade, integridade e disponibilidade dos sistemas críticos da Cliente.

Apesar das vulnerabilidades identificadas, a Cliente demonstra uma postura de segurança proativa, sustentada por controlos físicos adequados, pela utilização de soluções EDR e pela segmentação da rede. As recomendações apresentadas neste relatório têm como objetivo mitigar os riscos identificados e elevar o nível global de maturidade e resiliência da segurança da infraestrutura.

72/100

Pontuação de Risco Global

Nível de risco: **ALTO** - Requer ação imediata em áreas críticas

Metodologia de Cálculo da Pontuação de Risco

A **Pontuação de Risco Global (72/100)** é calculada através de uma metodologia baseada em CVSS (Common Vulnerability Scoring System), onde cada vulnerabilidade recebe um peso proporcional à sua severidade: **Alta (peso 10)**, **Média (peso 5)**, e **Baixa (peso 2)**. A pontuação final considera o número total de vulnerabilidades (20), a distribuição por severidade (4 Altas, 7 Médias, 9 Baixas), e o impacto potencial em áreas críticas como Active Directory, aplicações web e infraestrutura de rede.

> **Cálculo:** (4 Altas × 10) + (7 Médias × 5) + (9 Baixas × 2) = 93 pontos / 130 máximo = **71.5 ≈ 72/100**
> Uma pontuação acima de **70 indica risco elevado** que requer intervenção prioritária da gestão. Adicionalmente, cada vulnerabilidade recebe uma pontuação individual (0-10) baseada em impacto, exploitabilidade, criticidade dos ativos e alcance (ver secção "Top 10 Vulnerabilidades").

Métricas Principais

A auditoria identificou **20 vulnerabilidades** distribuídas por 6 categorias de segurança. A análise de severidade revela **4 vulnerabilidades de nível alto** que representam riscos críticos para a continuidade do negócio e requerem ação imediata. As vulnerabilidades impactam **5 normas e regulamentos** de conformidade, incluindo ISO 27001, GDPR e NIST CSF.

20

Total de Vulnerabilidades

4

Severidade Alta

7

Severidade Média

9

Severidade Baixa

6

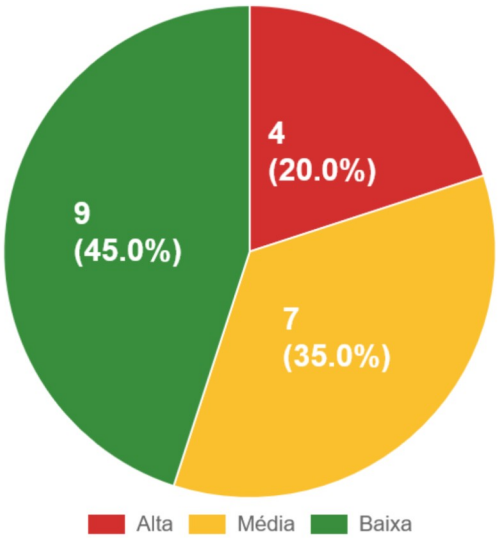
Categorias Afetadas

5

Normas em Risco

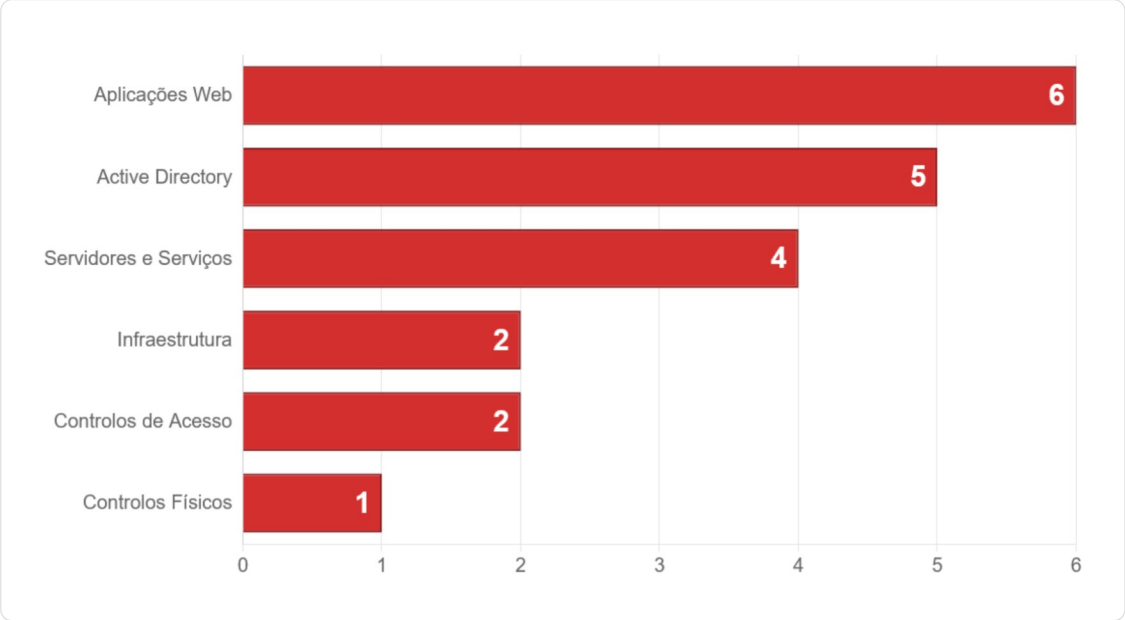
Distribuição de Vulnerabilidades por Severidade

A distribuição de severidade mostra que **20% das vulnerabilidades são de severidade Alta**, representando os riscos mais críticos que podem comprometer sistemas essenciais. As vulnerabilidades de **severidade Média (35%)** também requerem atenção prioritária, pois podem ser encadeadas para aumentar o impacto de um ataque. Embora as **vulnerabilidades Baixas (45%)** representem menor risco imediato, a sua remediação fortalece a postura geral de segurança e reduz a superfície de ataque.



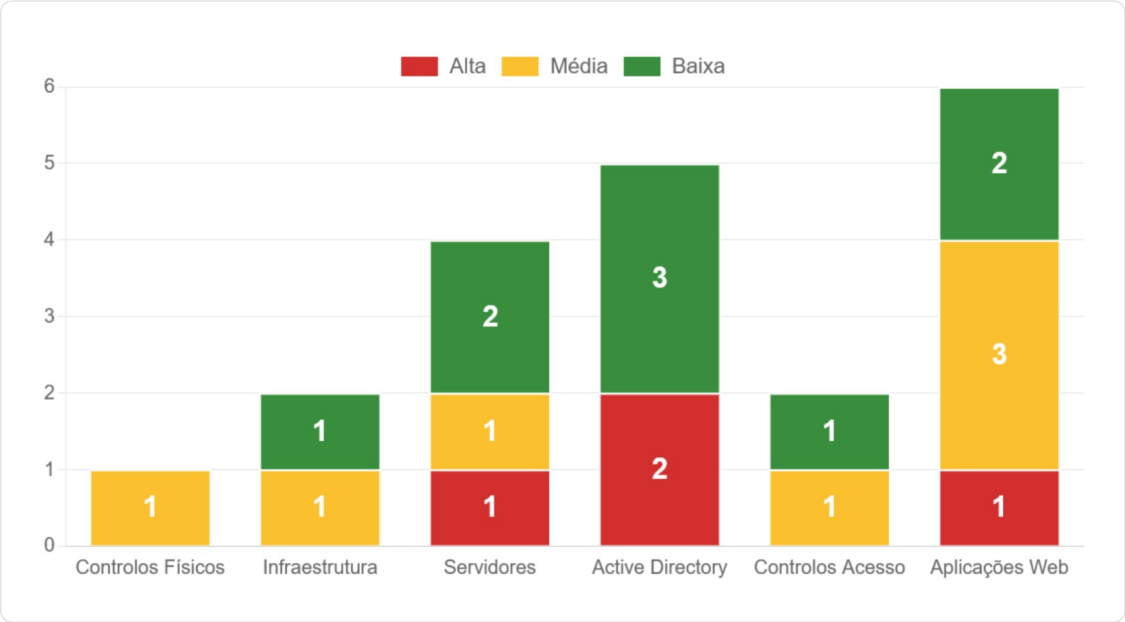
Vulnerabilidades por Categoria

A análise por categoria revela que **Aplicações Web (6 vulnerabilidades)** e **Active Directory (5 vulnerabilidades)** são as áreas mais expostas. As aplicações web internas, embora não expostas externamente, podem ser exploradas por utilizadores maliciosos com acesso à rede interna ou por atacantes após comprometerem o perímetro. O Active Directory, enquanto espinha dorsal da autenticação e autorização corporativa, representa um alvo crítico - o seu comprometimento pode resultar no controlo total da infraestrutura. Vulnerabilidades em **Servidores e Serviços (4)** também merecem prioridade devido à potencial escalada de privilégios e movimentação lateral na rede interna.



Análise Detalhada: Severidade por Categoria

Esta análise cruzada permite identificar **onde estão concentrados os riscos mais críticos**. Destaque para **Active Directory com 2 vulnerabilidades Altas** (Kerberoasting e Permissões em GPOs), representando o maior risco agregado para a infraestrutura. **Aplicações Web apresentam 3 vulnerabilidades Médias** que, embora individualmente menos críticas, aumentam significativamente a superfície de ataque interna. A categoria de **Servidores e Serviços possui 1 vulnerabilidade Alta** (falhas de patch management) que expõe sistemas críticos a exploits conhecidos. Esta distribuição indica que o foco de remediação deve priorizar Active Directory, seguido de Servidores e Aplicações Web.



Principais Ameaças Identificadas

Vulnerabilidades

⚠ **Kerberoasting (L09 - Alta):** Contas privilegiadas com SPNs configurados podem ser exploradas para extrair tickets Kerberos e quebrar senhas offline, comprometendo potencialmente todo o domínio.

⚠ **Permissões Excessivas em GPOs (L08 - Alta):** Permissões inadequadas em Group Policy Objects permitem que atacantes modifiquem políticas críticas, afetando múltiplas máquinas e utilizadores.

⚠ **Falhas de Patch Management (L04 - Alta):** Sistemas desatualizados, incluindo um servidor Windows 2003 vulnerável ao Eternal Blue (MS17-010), representam pontos de entrada para exploração remota.

⚠ **Comunicação HTTP Não Cifrada (L15 - Alta):** Aplicações críticas transmitem dados sem encriptação, expondo credenciais e informação sensível a ataques Man-in-the-Middle.

⚠ **Protocolos Inseguros Ativos (L05 - Média):** LLMNR e NetBIOS permitem captura de credenciais através de ataques de poisoning, facilitando movimento lateral na rede.

Impacto no Negócio

As vulnerabilidades identificadas representam riscos significativos para as operações da Cliente. Um ataque bem-sucedido explorando estas falhas pode resultar em:

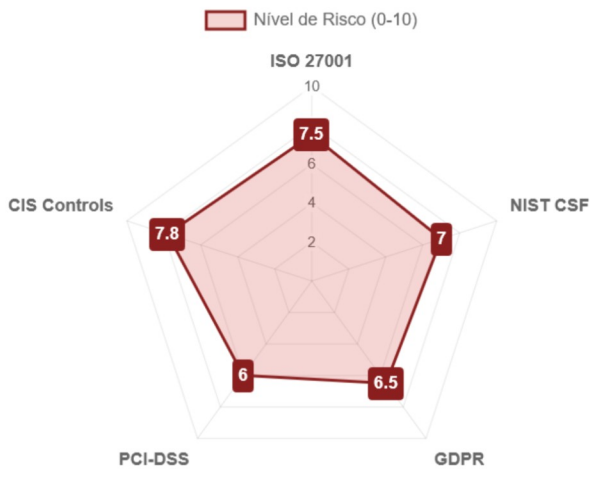
- **Comprometimento de Dados Confidenciais**
- **Interrupção de Serviços Críticos**
- **Perdas Financeiras e Reputacionais**
- **Não Conformidade Regulatória**

Análise de Risco: Sem mitigação das vulnerabilidades identificadas, especialmente as de severidade Alta (CVSS ≥7.0), existe um risco significativo de comprometimento por atacantes internos ou externos que tenham obtido acesso inicial à rede interna. A presença de vulnerabilidades críticas como MS17-010 (CVSS 9.0) e Kerberoasting (CVSS 8.8) constitui uma ameaça à segurança da infraestrutura.

Risco de Não Conformidade com Normas e Regulamentos

As vulnerabilidades identificadas impactam diretamente a conformidade da Cliente com normas e regulamentos de segurança da informação reconhecidos internacionalmente:

- **ISO/IEC 27001:** Norma internacional para gestão de segurança da informação, define requisitos para sistemas de gestão de SI
- **NIST CSF:** Framework de Cibersegurança do National Institute of Standards and Technology (EUA), focado em identificar, proteger, detetar, responder e recuperar
- **GDPR:** Regulamento Geral de Proteção de Dados da UE, obrigatório para empresas que processam dados pessoais de cidadãos europeus
- **PCI-DSS:** Payment Card Industry Data Security Standard, obrigatório para organizações que processam pagamentos com cartão
- **CIS Controls:** Conjunto de 18 controlos críticos de segurança desenvolvidos pelo Center for Internet Security



Norma/ Regulamento	Nível de Risco	Vulnerabilidades Relacionadas	Impacto Principal
ISO/IEC 27001	**ALTO (7.5/10)**	L04, L08, L09, L10, L15	Gestão de ativos, controlo de acessos, criptografia
NIST CSF	**ALTO (7.0/10)**	L04, L05, L08, L13, L15	Proteção, Deteção e Resposta a incidentes
GDPR	**MÉDIO (6.5/10)**	L01, L02, L07, L15, L20	Proteção de dados pessoais, confidencialidade
PCI-DSS	**MÉDIO (6.0/10)**	L01, L04, L13, L15, L18	Segurança de rede, criptografia, gestão de acessos
CIS Controls	**ALTO (7.8/10)**	L04, L08, L09, L10, L11, L12	Gestão de vulnerabilidades, configurações seguras

Top 10 Vulnerabilidades por Pontuação de Risco

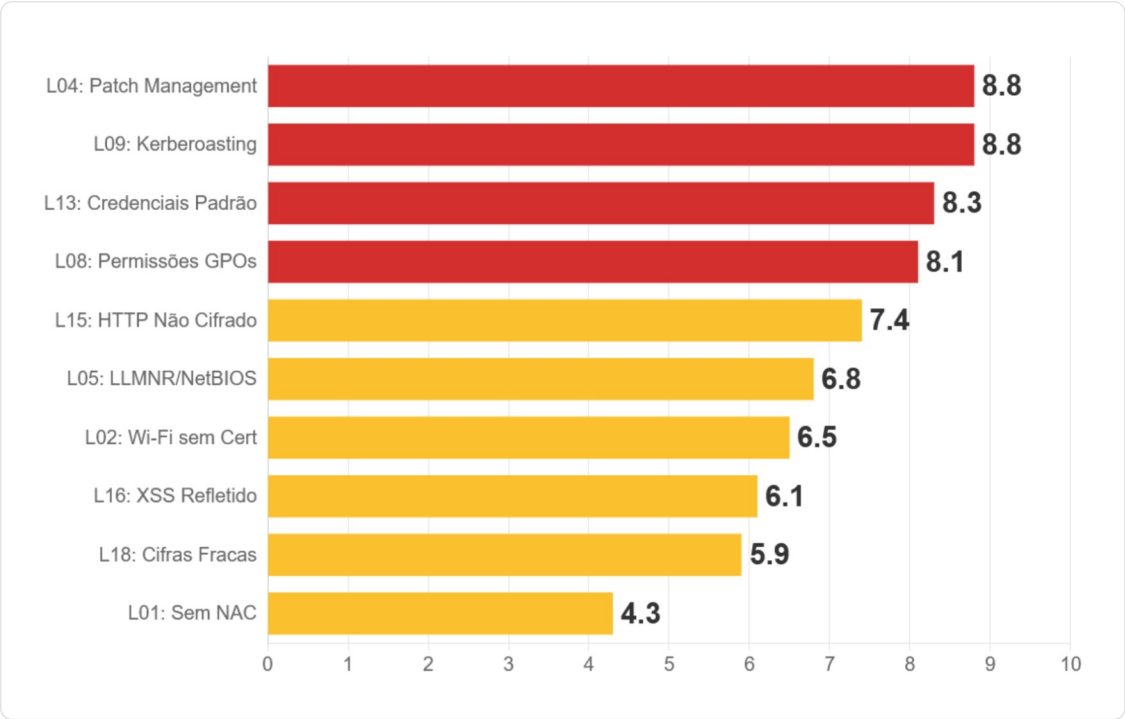
Metodologia de Pontuação Individual - CVSS v3.1

Cada vulnerabilidade é avaliada usando o **CVSS v3.1 (Common Vulnerability Scoring System)**, o standard internacional da indústria mantido pelo FIRST.org e utilizado pelo NIST National Vulnerability Database. As pontuações (0.0-10.0) são calculadas com base em métricas objetivas:

- **Attack Vector (AV):** Rede, Adjacente, Local ou Físico
- **Attack Complexity (AC):** Complexidade técnica de exploração
- **Privileges Required (PR):** Nível de privilégios necessários
- **User Interaction (UI):** Requer ou não interação do utilizador
- **Scope (S):** Impacto limitado ao componente ou estendido a outros
- **CIA Impact:** Impacto em confidencialidade, Integridade e Disponibilidade

Referência: CVSS v3.1 Calculator - FIRST.org

> **Escala de Severidade CVSS:** Crítica (9.0-10.0) | Alta (7.0-8.9) | Média (4.0-6.9) | Baixa (0.1-3.9)


L04: Patch Management
8.8
L09: Kerberoasting
8.8
L13: Credenciais Padrão
8.3
L08: Permissões GPOs
8.1
L15: HTTP Não Cifrado
7.4
L05: LLMNR/NetBIOS
6.8
L02: Wi-Fi sem Cert
6.5
L16: XSS Refletido
6.1
L18: Cifras Fracas
5.9
L01: Sem NAC
4.3
0
1
2
3
4
5
6
7
8
9
10

Recomendações Estratégicas por Prioridade

Ação Imediata (0-30 dias)

- Aplicar patches críticos, especialmente MS17-010
- Corrigir permissões excessivas em GPOs
- Remover SPNs de contas administrativas
- Implementar HTTPS em todas as aplicações web
- Desativar protocolos LLMNR e NetBIOS

Curto Prazo (1-3 meses)

- Implementar MFA para todas as contas administrativas
- Estabelecer processo formal de patch management
- Ativar SMB Signing obrigatório
- Implementar autenticação por certificado no Wi-Fi
- Adicionar Domain Admins ao grupo Protected Users
- Remediar vulnerabilidades de aplicações web (XSS, Basic Auth)

Longo Prazo (3-12 meses)

- Implementar solução de NAC para rede cablada
- Avaliar e atualizar certificados SSL/TLS
- Implementar solução de gestão de passwords
- Realizar análise de maturidade ISO 27001
- Desenvolver plano estratégico de segurança
- Implementar monitorização contínua de segurança (SIEM)

Recomendações Adicionais para o Board

✓ **Governança e Compliance:** Estabelecer um programa formal de gestão de riscos de segurança alinhado com ISO 27001 e NIST CSF.

✓ **Formação e Sensibilização:** Implementar programa de awareness de segurança para todos os colaboradores, com foco em phishing e engenharia social.

✓ **Testes Regulares:** Realizar pentests internos e externos com periodicidade anual, complementados com avaliações de vulnerabilidades trimestrais.

✓ **Incident Response Plan:** Desenvolver e testar um plano de resposta a incidentes, incluindo procedimentos de backup e recuperação de desastres.

Aspetos Positivos Identificados

- ✓ **Controlos Físicos:** Acesso às instalações bem controlado com segurança e sistema de cartões.
- ✓ **EDR Implementado:** Soluções CrowdStrike ativas que detetaram e bloquearam atividades maliciosas durante os testes.
- ✓ **Protocolos Modernos:** Ausência de NTLMv1, com preferência por Kerberos para autenticação.
- ✓ **Segmentação de Rede:** Forests do Active Directory devidamente segregadas, limitando movimento lateral.
- ✓ **Gestão de Portas:** Portas de rede desativadas por padrão, requerendo ativação manual controlada.

Conclusão

A Cliente demonstra uma preocupação genuína com a segurança da informação, evidenciada pelos controlos já implementados. No entanto, as vulnerabilidades identificadas, particularmente as de severidade alta, representam riscos significativos que devem ser endereçados prioritariamente.

Recomendação Final: A **LAYER8** recomenda fortemente a implementação imediata das ações de curto prazo (0-3 meses), com alocação de recursos dedicados e acompanhamento executivo. Um follow-up de reavaliação é recomendado em 6 meses para validar a eficácia das medidas implementadas.

Com a implementação das recomendações deste relatório, a Cliente poderá reduzir significativamente a sua superfície de ataque e alcançar um nível de maturidade de segurança alinhado com as melhores práticas internacionais e requisitos de conformidade regulatória.